

ĐỀ XUẤT ĐỀ TÀI KHÓA LUẬN TỐT NGHIỆP

Chuyên ngành: Kỹ thuật phần mềm

Định hướng: Ứng dụng thực tế - Java Backend - Web Security

XÂY DỰNG NỀN TẢNG WEB KIỂM TRA VÀ CẢNH BÁO RỦI RO LỪA ĐẢO TRỰC TUYẾN TRONG GIAO DỊCH ĐỜI SỐNG BẰNG JAVA BACKEND

Development of a Java Backend-based Web Platform for Online Scam and Phishing Risk Detection in Daily Transactions

Nội dung	Thông tin đề xuất
Loại đề tài	Ứng dụng
Lĩnh vực	Web Security, Anti-phishing, Scam Warning, Java Backend
Nền tảng triển khai	Web application
Công nghệ trọng tâm	Java, Spring Boot, Spring Security, PostgreSQL, Redis, Docker
Sản phẩm đầu ra	Website + REST API + dashboard cảnh báo + báo cáo rủi ro
Phạm vi	Kiểm tra URL, biểu mẫu, tin nhắn, số điện thoại, số tài khoản và giao dịch đời sống

Tóm tắt kết hợp:

Đề tài này kết hợp hai hướng ban đầu: anti-phishing web và cảnh báo rủi ro lừa đảo trong giao dịch đời sống. Hệ thống vừa kiểm tra link/form giả mạo, vừa phân tích tin nhắn, số điện thoại, số tài khoản và báo cáo cộng đồng để đưa ra cảnh báo rủi ro cho người dùng phổ thông.

1. Tổng quan đề tài

Trong đời sống số hiện nay, người dùng thường xuyên tiếp nhận các đường link, biểu mẫu, tin nhắn giao dịch, số điện thoại hoặc số tài khoản từ nhiều nguồn khác nhau như Zalo, Facebook, email, SMS, sàn thương mại điện tử, nhóm mua bán online, tuyển dụng, thuê trọ hoặc đặt vé sự kiện.

Tuy nhiên, đây cũng là môi trường dễ phát sinh nhiều hình thức lừa đảo trực tuyến như website giả mạo, form thu thập thông tin cá nhân, link nhận quà giả, tin nhắn yêu cầu chuyển tiền gấp, tài khoản ngân hàng bị nhiều người báo cáo hoặc nội dung giao dịch có dấu hiệu bất thường.

Vì vậy, đề tài hướng đến việc xây dựng một nền tảng web giúp người dùng kiểm tra nhanh mức độ rủi ro trước khi bấm vào liên kết, nhập thông tin cá nhân hoặc thực hiện giao dịch chuyển khoản. Hệ thống đóng vai trò như một công cụ cảnh báo sớm, giúp người dùng phổ thông nhận diện rủi ro lừa đảo một cách dễ hiểu và trực quan.

2. Ý tưởng kết hợp từ hai đề tài ban đầu

Đề tài được hình thành bằng cách gộp hai hướng nghiên cứu và triển khai thành một hệ thống thống nhất: kiểm tra liên kết/biểu mẫu giả mạo và cảnh báo rủi ro lừa đảo trong giao dịch đời sống.

2.1. Hướng kiểm tra liên kết và biểu mẫu giả mạo

Hệ thống có khả năng kiểm tra các yếu tố liên quan đến website hoặc biểu mẫu đáng nghi, bao gồm:

- Đường link có dấu hiệu giả mạo hay không.
- Tên miền có gần giống thương hiệu thật hay không.
- Website có sử dụng HTTPS hợp lệ hay không.
- Có chuyển hướng qua nhiều domain lạ hay không.
- Nội dung trang có sử dụng từ khóa dụ dỗ, khẩn cấp hoặc gây áp lực hay không.
- Biểu mẫu có yêu cầu thông tin nhạy cảm như mật khẩu, OTP, CCCD, số thẻ hoặc thông tin ngân hàng hay không.
- Header và cấu hình website có thiếu các yếu tố bảo mật cơ bản hay không.

2.2. Hướng cảnh báo rủi ro lừa đảo trong giao dịch đời sống

Hệ thống không chỉ kiểm tra link mà còn mở rộng sang các tình huống giao dịch online hằng ngày, bao gồm:

- Kiểm tra nội dung tin nhắn hoặc đoạn hội thoại đáng nghi.
- Kiểm tra bài đăng mua bán, thuê trọ, tuyển dụng hoặc đặt cọc.
- Kiểm tra số điện thoại có từng bị báo cáo lừa đảo hay không.
- Kiểm tra số tài khoản ngân hàng có nằm trong danh sách rủi ro hay không.
- Cho phép người dùng gửi báo cáo lừa đảo mới.
- Cho phép quản trị viên kiểm duyệt và cập nhật dữ liệu cảnh báo cộng đồng.

Như vậy, đề tài sau khi kết hợp không chỉ là một công cụ anti-phishing, mà là một nền tảng cảnh báo lừa đảo trực tuyến toàn diện hơn, phù hợp với nhu cầu thực tế của người dùng phổ thông.

3. Mục tiêu của đề tài

- Xây dựng một nền tảng web cho phép người dùng kiểm tra URL, biểu mẫu, nội dung tin nhắn, số điện thoại, số tài khoản và thông tin giao dịch đáng nghi.
- Thiết kế cơ chế chấm điểm rủi ro dựa trên tập luật bảo mật, dữ liệu cộng đồng và các dấu hiệu lừa đảo phổ biến.

- Cung cấp kết quả cảnh báo dễ hiểu cho người dùng, bao gồm điểm rủi ro, mức độ cảnh báo, nguyên nhân và khuyến nghị xử lý.
- Xây dựng backend bằng Java Spring Boot với kiến trúc rõ ràng, có xác thực, phân quyền, lưu lịch sử kiểm tra và khả năng mở rộng.
- Xây dựng dashboard quản trị để quản lý dữ liệu cảnh báo, luật chấm điểm, báo cáo người dùng và thống kê rủi ro.
- Tạo bộ dữ liệu mẫu phục vụ kiểm thử và demo các tình huống lừa đảo phổ biến trong đời sống.

4. Đối tượng sử dụng

- Người dùng phổ thông thường xuyên nhận link, tin nhắn hoặc giao dịch online.
- Sinh viên, nhân viên văn phòng, phụ huynh và người lớn tuổi cần công cụ hỗ trợ nhận diện rủi ro.
- Người mua hàng online, người thuê trọ, người tìm việc, người mua vé sự kiện hoặc giao dịch đồ cũ.
- Quản trị viên cộng đồng hoặc nhóm kiểm duyệt cần quản lý báo cáo lừa đảo.
- Trường học, câu lạc bộ hoặc doanh nghiệp nhỏ muốn nâng cao nhận thức về an toàn thông tin.

5. Phạm vi đề tài

Đề tài tập trung vào việc xây dựng một hệ thống phần mềm ứng dụng, không đi sâu vào khai thác lỗ hổng kỹ thuật hoặc tấn công vào website thật.

- Kiểm tra URL, domain, HTTPS, redirect, header, HTML và biểu mẫu ở mức an toàn.
- Phân tích nội dung tin nhắn hoặc giao dịch dựa trên từ khóa và dấu hiệu rủi ro.
- Kiểm tra số điện thoại, số tài khoản và dữ liệu báo cáo cộng đồng.
- Xây dựng rule engine để tính điểm rủi ro.
- Xây dựng dashboard quản trị và báo cáo thống kê.
- Không lưu mật khẩu, OTP, số thẻ hoặc dữ liệu nhạy cảm của người dùng.
- Có thể sử dụng bộ dữ liệu mẫu hoặc dữ liệu giả lập để phục vụ demo và kiểm thử.

6. Chức năng chính của hệ thống

6.1. Chức năng cho người dùng

- Đăng ký, đăng nhập và quản lý tài khoản cá nhân.
- Nhập URL hoặc đường link đáng nghi để kiểm tra.
- Dán nội dung biểu mẫu hoặc nội dung trang web để phân tích.
- Dán nội dung tin nhắn, bài đăng giao dịch hoặc đoạn hội thoại đáng nghi.
- Kiểm tra số điện thoại hoặc số tài khoản ngân hàng.
- Xem kết quả đánh giá rủi ro theo điểm số.
- Xem mức cảnh báo: an toàn, cần cẩn trọng hoặc nguy hiểm.
- Xem giải thích vì sao hệ thống đánh giá thông tin đó là đáng nghi.
- Nhận khuyến nghị xử lý như không bấm link, không nhập OTP, không chuyển tiền, xác minh lại nguồn gửi.
- Xem lịch sử các lần kiểm tra.
- Gửi báo cáo lừa đảo mới để quản trị viên kiểm duyệt.

6.2. Chức năng cho quản trị viên

- Quản lý người dùng.
- Quản lý danh sách domain, URL, số điện thoại, số tài khoản và từ khóa rủi ro.

- Quản lý bộ luật chấm điểm rủi ro.
- Duyệt, xác minh hoặc từ chối báo cáo do người dùng gửi lên.
- Theo dõi dashboard thống kê số lượt kiểm tra, số báo cáo mới, loại rủi ro phổ biến.
- Xuất báo cáo PDF hoặc HTML theo ngày, tuần, tháng.
- Cập nhật danh sách domain tin cậy và domain nghi ngờ.
- Theo dõi nhật ký thao tác quan trọng trong hệ thống.

7. Tiêu chí kiểm tra rủi ro

Hệ thống đánh giá rủi ro dựa trên nhiều nhóm tiêu chí khác nhau. Các tiêu chí này có thể được cấu hình thành các luật chấm điểm trong Rule Engine.

Nhóm kiểm tra	Ví dụ tiêu chí
Đường link và tên miền	Tên miền quá dài, gần giống thương hiệu thật, ký tự dễ gây nhầm lẫn, nhiều subdomain bất thường, link rút gọn hoặc domain từng bị báo cáo.
Kết nối và cấu hình website	Không dùng HTTPS, chứng chỉ SSL lỗi, chuyển hướng qua nhiều domain lạ, thiếu security headers hoặc lộ thông tin server.
Nội dung trang và biểu mẫu	Có từ khóa gây áp lực như xác minh ngay, tài khoản sẽ bị khóa, nhận thưởng gấp; form yêu cầu OTP, CCCD, mật khẩu hoặc thông tin ngân hàng không hợp lý.
Giao dịch đời sống	Tin nhắn thúc ép chuyển tiền nhanh, bài đăng yêu cầu đặt cọc thiếu xác minh, số điện thoại/số tài khoản từng bị báo cáo, nội dung giả mạo tuyển dụng/đặt phòng/mua vé/hoàn tiền.
Lịch sử và dữ liệu cộng đồng	Nhiều người dùng báo cáo cùng một domain, số điện thoại, số tài khoản hoặc nội dung trong thời gian ngắn.

8. Quy trình xử lý nghiệp vụ

1. Người dùng nhập thông tin cần kiểm tra, có thể là URL, biểu mẫu, nội dung tin nhắn, số điện thoại, số tài khoản hoặc thông tin giao dịch.
2. Backend tiếp nhận và chuẩn hóa dữ liệu đầu vào.
3. Hệ thống tách các thành phần quan trọng như URL, domain, số điện thoại, số tài khoản, từ khóa và nội dung nhạy cảm.
4. Module kiểm tra web phân tích các yếu tố như HTTPS, SSL, redirect, header, HTML và form.
5. Module kiểm tra giao dịch đối chiếu dữ liệu với danh sách rủi ro trong database và cache.
6. Rule Engine tính điểm rủi ro dựa trên tập luật và trọng số.
7. Hệ thống phân loại kết quả thành các mức: an toàn, cần cẩn trọng hoặc nguy hiểm.
8. Backend trả về báo cáo gồm điểm rủi ro, nguyên nhân cảnh báo và khuyến nghị xử lý.
9. Nếu người dùng gửi báo cáo mới, quản trị viên sẽ kiểm duyệt trước khi đưa vào danh sách cảnh báo cộng đồng.
10. Hệ thống lưu lịch sử kiểm tra để người dùng và quản trị viên có thể tra cứu lại.

9. Kiến trúc hệ thống đề xuất

Hệ thống được thiết kế theo kiến trúc web client-server, trong đó frontend giao tiếp với backend thông qua REST API. Backend là trung tâm xử lý nghiệp vụ, kiểm tra bảo mật, lưu trữ dữ liệu và cung cấp API cho frontend.

Thành phần	Vai trò
Frontend Web	Giao diện nhập thông tin cần kiểm tra, xem kết quả cảnh báo, lịch sử kiểm tra, gửi báo cáo và dashboard quản trị.
Java Spring Boot Backend	Xử lý API, xác thực, phân quyền, nghiệp vụ kiểm tra rủi ro, quản lý báo cáo và kết nối các module xử lý.
Rule Engine	Chấm điểm rủi ro dựa trên tập luật và trọng số.
Scan Worker	Kiểm tra URL, lấy header, kiểm tra SSL, phân tích HTML, kiểm tra form và phát hiện dấu hiệu bất thường.
PostgreSQL	Lưu người dùng, lịch sử kiểm tra, kết quả rủi ro, báo cáo, dữ liệu cảnh báo và rule.
Redis	Cache dữ liệu rủi ro thường xuyên truy vấn như domain, số điện thoại, số tài khoản và từ khóa cảnh báo.
Scheduler	Kiểm tra lại các link quan trọng, cập nhật thống kê, gửi cảnh báo hoặc tạo báo cáo định kỳ.
Report Service	Tạo báo cáo PDF hoặc HTML cho từng lần kiểm tra hoặc báo cáo thống kê cho quản trị viên.

10. Công nghệ sử dụng

Thành phần	Công nghệ đề xuất
Backend	Java 17+, Spring Boot, Spring Web, Spring Data JPA
Security	Spring Security, JWT, BCrypt, Role-based Access Control
Database	PostgreSQL
Cache	Redis
Frontend	ReactJS hoặc Next.js
Xử lý URL/Web	Java HttpClient, Jsoup, Apache Commons Validator
Report	OpenPDF hoặc JasperReports
Testing	JUnit, Mockito, Testcontainers, Postman/Newman
Deployment	Docker, Docker Compose, Nginx, Render/Railway/VPS

11. Mô hình dữ liệu dự kiến

Bảng/Entity	Mục đích lưu trữ
User	Thông tin tài khoản, vai trò, trạng thái người dùng và thời gian tạo tài khoản.
ScanRequest	Thông tin mỗi lần người dùng gửi yêu cầu kiểm tra, loại dữ liệu, nội dung đầu vào và thời gian kiểm tra.
RiskResult	Điểm rủi ro, mức cảnh báo, lý do cảnh báo và khuyến nghị xử lý.
ScamReport	Báo cáo lừa đảo do người dùng gửi lên, bằng chứng, trạng thái kiểm duyệt và người xử lý.
RiskEntity	Các thực thể rủi ro như domain, URL, số điện thoại, số tài khoản, từ khóa hoặc mẫu nội dung đáng nghi.
RiskRule	Các luật chấm điểm rủi ro, trọng số và trạng thái kích hoạt của từng luật.
AuditLog	Lịch sử thao tác quan trọng của người dùng và quản trị viên.

12. Điểm mới và tính ứng dụng thực tế

Điểm mới của đề tài là kết hợp hai hướng bảo vệ người dùng: kiểm tra rủi ro kỹ thuật của website, URL và biểu mẫu; đồng thời kiểm tra rủi ro giao dịch đời sống như tin nhắn, số điện thoại, số tài khoản và nội dung chuyển tiền.

Nhiều công cụ bảo mật hiện nay thường hướng đến chuyên gia kỹ thuật, trong khi người dùng phổ thông cần một công cụ dễ sử dụng, giải thích ngắn gọn và đưa ra khuyến nghị rõ ràng.

Đề tài có tính ứng dụng cao vì có thể sử dụng trong trường học, gia đình, cộng đồng mua bán online, nhóm sinh viên, doanh nghiệp nhỏ hoặc các tổ chức muốn nâng cao nhận thức về an toàn thông tin.

13. Kết quả dự kiến

- Một website hoạt động được, cho phép kiểm tra link, biểu mẫu, tin nhắn, số điện thoại, số tài khoản và thông tin giao dịch.
- Một backend Java Spring Boot có API rõ ràng, xác thực JWT và phân quyền USER/ADMIN.
- Cơ sở dữ liệu PostgreSQL lưu lịch sử kiểm tra, báo cáo và dữ liệu cảnh báo.
- Module Rule Engine có thể chấm điểm rủi ro dựa trên tập luật cấu hình được.
- Module Scan Worker kiểm tra URL, SSL, header, HTML và form.
- Dashboard quản trị thống kê rủi ro, báo cáo người dùng và xu hướng cảnh báo.
- Chức năng xuất báo cáo PDF hoặc HTML.
- Tài liệu phân tích yêu cầu, thiết kế hệ thống, thiết kế database, API, kiểm thử và hướng dẫn triển khai.

14. Hướng phát triển mở rộng

- Tích hợp AI hoặc LLM để phân tích nội dung tin nhắn lừa đảo phức tạp hơn.
- Tích hợp OCR để người dùng chụp màn hình tin nhắn hoặc giao dịch, hệ thống tự trích xuất nội dung.
- Tích hợp tiện ích trình duyệt để cảnh báo khi người dùng truy cập link đáng ngờ.
- Xây dựng hệ thống điểm uy tín cho báo cáo cộng đồng.
- Kết nối với các nguồn dữ liệu công khai về domain độc hại hoặc danh sách cảnh báo an toàn thông tin.
- Tích hợp thông báo email hoặc push notification khi một link từng kiểm tra thay đổi trạng thái rủi ro.

15. Lý do đề tài phù hợp với chuyên ngành Kỹ thuật phần mềm

Đề tài phù hợp với chuyên ngành Kỹ thuật phần mềm vì trọng tâm không chỉ là áp dụng một thuật toán bảo mật đơn lẻ, mà là xây dựng một hệ thống phần mềm hoàn chỉnh.

Sinh viên cần thực hiện đầy đủ các bước trong quy trình phát triển phần mềm như khảo sát nhu cầu, phân tích yêu cầu, thiết kế kiến trúc, thiết kế cơ sở dữ liệu, xây dựng REST API, xây dựng giao diện người dùng và dashboard quản trị, kiểm thử chức năng, kiểm thử bảo mật cơ bản, kiểm thử API, triển khai hệ thống bằng Docker và đánh giá kết quả.

Bên cạnh đó, đề tài thể hiện rõ năng lực Backend Java thông qua các thành phần như Spring Boot, Spring Security, JWT, phân quyền, xử lý nghiệp vụ, rule engine, scheduler, cache, report service, logging và testing.

16. Kết luận

Đề tài “Xây dựng nền tảng web kiểm tra và cảnh báo rủi ro lừa đảo trực tuyến trong giao dịch đời sống bằng Java Backend” là một đề tài có tính thực tế cao, phù hợp với bối cảnh lừa đảo trực tuyến ngày càng phổ biến trong đời sống số.

Đề tài kết hợp cả hai hướng: kiểm tra liên kết và biểu mẫu giả mạo, đồng thời cảnh báo rủi ro trong các giao dịch đời sống như tin nhắn, số điện thoại, số tài khoản và nội dung chuyển khoản. Nhờ đó, hệ thống không chỉ hỗ trợ nhận diện website giả mạo mà còn giúp người dùng phòng tránh các tình huống lừa đảo thường gặp trước khi thực hiện giao dịch.

Đây là một đề tài phù hợp cho khóa luận tốt nghiệp theo định hướng ứng dụng thực tế, có ý nghĩa xã hội, có khả năng triển khai thành sản phẩm demo và thể hiện rõ năng lực kỹ thuật trong Java Backend, thiết kế hệ thống, Web Security và kiểm thử phần mềm.